

Enterprise Information Security

Security Standards

Enterprise Information Security Standards

DOC-SEC-STD V-3.0

Effective Date: 01/02/2026

SENSITIVITY CLASSIFICATION: Internal Use

Table of Contents

Revision History 3

1. Introduction 3

 1.1 Purpose 3

 1.2 Scope 3

2. Identity and Access Management 3

 2.1 Identity Lifecycle 3

 2.2 Authentication 3

 2.3 Least Privilege 4

3. Network Security 4

 3.1 Segmentation and Zoning 4

 3.2 Secure Remote Access 5

4. Application Security 5

 4.1 Secure Development Lifecycle 5

 4.2 Secure Coding 5

 4.3 API Security 5

5. Cryptography 5

 5.1 Cryptographic Standards 6

 5.2 Key Management 6

6. Logging, Monitoring and Incident Response 6

 6.1 Logging and Monitoring 6

 6.2 Incident Severity Classification 6

7. Third-Party and Vendor Security 7

 7.1 Vendor Security Risk Assessment 7

Appendix A: Glossary of Terms 7

Revision History

Version	Date	Changed By	Description
2.0	2024-09-30	T. Alvarez	Cloud security added
3.0	2026-02-01	T. Alvarez	Aligned to revised risk appetite

1. Introduction

1.1 Purpose

This document defines the Security Standards that govern how systems, applications, networks and data are protected against unauthorised access, disclosure, alteration and disruption.

1.2 Scope

These standards apply to all systems, applications, infrastructure and data owned or operated by the organisation, and to third parties that access, process or host organisational data. They are binding for internal teams, contractors and external vendors.

2. Identity and Access Management

2.1 Identity Lifecycle

Statement: Identities must be provisioned, modified and de-provisioned through a controlled, auditable process aligned to employment or engagement status.

Rationale: Stale or orphaned accounts are a leading cause of unauthorised access.

Requirements:

- Provisioning must be tied to an authoritative source such as the HR system
- Access must be revoked within one business day of termination
- Dormant accounts exceeding 90 days of inactivity must be disabled automatically

2.2 Authentication

Statement: All access must be authenticated using mechanisms appropriate to the sensitivity of the system, with multi-factor authentication required for privileged and remote access.

Rationale: Passwords alone are increasingly insufficient against credential-based attacks.

Requirements:

- MFA must be enforced for all remote access, administrative access, and access to Confidential or Restricted systems
- Shared or generic accounts must be avoided; where unavoidable, usage must be logged
- Default vendor credentials must be changed before production deployment

Control	Minimum Standard
Password length	Minimum 12 characters; 14 or more for privileged accounts
Password complexity	Upper and lower case, numbers and symbols, or an equivalent passphrase policy
Multi-factor authentication	Required for remote, administrative and Confidential system access
Account lockout	After five consecutive failed attempts
Session timeout	30 minutes of inactivity; 15 minutes for privileged sessions

2.3 Least Privilege

Statement: Access must be granted on the principle of least privilege using role-based access control, and must be formally requested and approved.

Rationale: Least privilege constrains what any single identity can access or perform.

Requirements:

- Access must be granted through defined roles rather than ad hoc individual permissions
- Segregation of duties must be enforced for high-risk transactions
- Access approvals must be documented and retained for audit

3. Network Security

3.1 Segmentation and Zoning

Statement: Networks must be segmented into security zones based on trust level and data sensitivity, with controlled traffic flow between them.

Rationale: Segmentation contains the blast radius of a compromise.

Requirements:

- Production, non-production and management networks must be separated
- Traffic between zones must pass through a defined control point with explicit allow rules
- Systems handling Confidential data must reside in a zone with elevated controls

Zone	Purpose	Typical Controls
External / DMZ	Internet-facing services	Reverse proxy, WAF, strict inbound filtering
Internal	General user workstations and services	Standard firewalling, endpoint protection
Application / Data	Business applications and databases	Restricted east-west traffic, enhanced monitoring
Management	Infrastructure and administrative access	Jump hosts, MFA, strict access lists

3.2 Secure Remote Access

Statement: Remote access to internal systems must be provided through an approved, encrypted and authenticated solution.

Rationale: Unmanaged remote access pathways are a common entry point for attackers.

Requirements:

- Remote access must require MFA and use encrypted channels
- Remote access logs must be retained and available for monitoring

4. Application Security

4.1 Secure Development Lifecycle

Statement: Security requirements, threat modelling and security testing must be integrated into each phase of the software development lifecycle.

Rationale: Addressing security during design is materially cheaper than remediating after release.

Requirements:

- Threat modelling must be performed for new applications and significant architectural changes
- Static analysis and dependency scanning must run in the build pipeline
- Security defects above a defined severity must be remediated before production release

4.2 Secure Coding

Statement: Applications must be developed in accordance with secure coding practices and tested for common vulnerability classes before release.

Rationale: The majority of application breaches exploit well-known, preventable vulnerability classes.

Requirements:

- Input validation and output encoding must be applied to prevent injection and cross-site scripting
- Third-party dependencies must be scanned for known vulnerabilities and kept current
- Sensitive data must not be logged, cached or exposed in error messages

4.3 API Security

Statement: APIs must be authenticated, authorised, rate-limited and validated consistently with other application interfaces.

Rationale: APIs are exposed to a broader range of consumers and require explicit controls rather than obscurity.

Requirements:

- APIs must require authentication and enforce authorisation on every request
- Rate limiting must be applied to protect against abuse and denial of service
- Input payloads must be validated against a defined contract

5. Cryptography

5.1 Cryptographic Standards

Statement: Encryption must use currently approved, industry-standard algorithms and key lengths for all Confidential and Restricted data, at rest and in transit.

Rationale: Algorithms weaken over time as computing power and cryptanalysis advance.

Requirements:

- Data in transit must use TLS 1.2 or higher
- Deprecated protocols and cipher suites must be disabled
- Unencrypted transport of Confidential data is prohibited on all networks, including private ones

5.2 Key Management

Statement: Cryptographic keys must be generated, stored, rotated and retired through a dedicated key management process, separate from the data they protect.

Rationale: Keys stored alongside the data they protect undermine encryption entirely if compromised together.

Requirements:

- Keys must be held in a dedicated key management service or hardware security module
- Key rotation schedules must be defined and enforced
- Keys must never be embedded in source code or configuration files

6. Logging, Monitoring and Incident Response

6.1 Logging and Monitoring

Statement: Systems must generate security-relevant logs which are centrally collected and retained for a defined period.

Rationale: Without centralised, tamper-resistant logging, malicious activity cannot be detected or reconstructed.

Requirements:

- Logs must capture authentication events, privileged actions and configuration changes
- Logs must be forwarded to the central platform and protected from modification
- Log retention must align with regulatory and investigative requirements

6.2 Incident Severity Classification

Incidents must be classified by severity to determine response priority and stakeholder notification.

Severity	Definition	Example	Initial Response
Critical	Severe impact to critical systems, data or safety	Active ransomware, large-scale breach	Within the hour
High	Significant impact; contained but serious	Confirmed unauthorised access to Confidential data	Same business day
Medium	Limited impact; single system or contained scope	Isolated malware detection, policy violation	Within 2 business days

Low	Minimal impact; informational or precautionary	Suspicious but unconfirmed activity	Within 5 business days
-----	--	-------------------------------------	------------------------

7. Third-Party and Vendor Security

7.1 Vendor Security Risk Assessment

Statement: Third parties that access, process or host organisational data must undergo a security risk assessment proportionate to the engagement before onboarding.

Rationale: Third-party relationships extend the attack surface beyond direct control.

Requirements:

- Vendors handling Confidential data must evidence an adequate control environment
- Findings must be documented, risk-rated and tracked to remediation
- High-risk vendors must be reassessed periodically for the duration of the engagement

Appendix A: Glossary of Terms

Term	Definition
Defence in Depth	Layered controls so the failure of one does not result in compromise.
MFA	Multi-Factor Authentication · two or more independent verification factors.
WAF	Web Application Firewall · filters and monitors HTTP traffic to an application.
Zero Trust	Continuous verification of every user and device regardless of network location.